

# When Calibration Fails: A Failure-Aware Public-Feed Gate for Vulnerability Prioritization Under Sparse Exploit Labels

Harshavardhan Malla Independent Researcher

**Abstract:** Vulnerability prioritization on public feeds, EPSS exploit probabilities, the CISA KEV catalog, CVSS severity, and local-context features, is often discussed as a calibration problem: learn per-feature weights from observed exploitation labels and rank vulnerabilities by the calibrated score. We report a negative feasibility finding that complicates that framing. Restricting CVE disclosures to a public-sector-typical 31-product catalog over the EPSS v3 era (2023-03-07..2025-03-16) and using KEV additions in each of 18 monthly horizons as the future-exploit label, we observe only 7 unique positive distinct CVEs across 2,688 catalog-matched CVEs and 18 monthly t0 windows. The pre-registered gate requires  $\geq 50$  unique positive CVEs for defensible per-feature calibration; the measured value is below the  $< 20$  PIVOT threshold. Calibration was not attempted under the gate. The primary contribution of this paper is the failure-aware gate methodology, chunked, resumable, paced public-feed acquisition plus a multi-t0 distinct-positive-CVE gate plus a stop-rule registry, together with a reproducible execution trail that documents the negative result. As a confirmatory secondary contribution we run a pre-registered sensitivity sweep with six fixed design-prior weight vectors across capacity, blackout, and feature-ablation axes on a real-feed extension of the VulnPrio study’s frozen synthetic-fleet benchmark. The sensitivity results are reported descriptively with paired-seed BCa CIs; no calibration claim, no model-comparison claim, and no production-readiness claim is made. This work does not claim model improvements; the synthetic fleet limits external validity, and a post-run variance criterion confirmed that within-cell seed variance dominates between-cell signal on every robustness axis, so sensitivity results are reported descriptively throughout.

## I. INTRODUCTION

Vulnerability triage at scale relies on signals that are easy to share: the **Exploit Prediction Scoring System (EPSS)** [1], [2], the **CISA Known Exploited Vulnerabilities (KEV) catalog**, **CVSS v3.1 / v4** severity, and local context such as asset criticality, network exposure, and remediation cost. Practitioners frequently combine these signals with hand-tuned or fitted weights. The fitted-weight path is attractive because calibration promises an estimator of risk grounded in observed exploitation outcomes. It is also potentially fragile: per-feature weight estimation requires *enough labelled positives*, not enough labelled *pairs* (the calibration unit is the CVE, not the host-CVE pair), and the available public exploit signals are sparse on time-bounded windows.

This paper is a companion to the VulnPrio study, which contributed a benchmark and scheduler for context-aware prioritization on a synthetic fleet with placeholder weights. The VulnPrio study made no calibration or model-quality claim. The present paper asks whether public-feed signals

can move us from placeholder weights toward weights with a calibrated interpretation. The honest answer is no, at the slice we examined. The negative finding is not a bug; it is a data-density boundary that needs to be acknowledged before public-feed calibration becomes a default move. The unit of analysis for per-feature weight learning is the distinct CVE-level positive, not the host-CVE record.

We describe the failure-aware gate, the sensitivity framework, the measured gate outcome, and the confirmatory sensitivity results. We position the work against EPSS / KEV / CVSS / SSVC and against recent capacity-constrained prioritization, EPSS-stability, and context-feature-ablation studies. We do not claim that any fixed prior matches or exceeds EPSS in any general sense. We do not claim deployment readiness. We do claim that the gate methodology is reproducible and that the negative feasibility result is informative.

## II. BACKGROUND

We operate over CVEs published in the National Vulnerability Database (NVD), with EPSS probabilities and CISA KEV status as feeds, and a synthetic endpoint fleet inherited from the VulnPrio study. The Paper-1 linear scoring formulation is preserved:

$$\text{score} = w_E \cdot E + w_K \cdot K + w_S \cdot S + w_C \cdot C + w_X \cdot X + w_U \cdot U - w_R \cdot R$$

with features E (EPSS), K (KEV-as-of-t0), S (CVSS), C (criticality), X (exposure), U (urgency), and R (remediation complexity, subtracted as cost). A scheduler selects per-cell capacity (top-K by score) under blackout policies; the operational outcome metric is the Exposure-Host-Day (EHD) burden over a horizon. The VulnPrio study’s frozen artefact is treated as read-only throughout this work and is verified before and after every CalibScore study batch.

Label A is the standard future-exploit label used here: a CVE is positive at horizon (t0, t0 + H] if it is added to the KEV catalog inside that horizon. KEV-as-of-t0 is used as the feature K (a leakage-safe separation: the feature uses past KEV state; the label uses future KEV state).

## III. RELATED WORK

We position this work against fifteen verified prior sources. We draw the differentiation explicitly to avoid claims of novelty in regions that prior work owns.

**EPSS family.** Jacobs et al. [1] introduced the EPSS exploit-probability estimator in DTRAP 2021 and refined it

in 2023 [2]; Ravalico et al. [3] examined EPSS temporal stability over ~45,000 CVEs. We do not retrain or re-tune EPSS. We use the released v3-era EPSS scores as a feature and report EPSS-only as a baseline. Our contribution is not EPSS evaluation; we use EPSS as one of several public-feed signals.

**CVSS / SSVC / scoring comparisons.** Koscinski et al. [4] report cross-system disagreement across CVSS, SSVC, EPSS, and the Exploitability Index on 600 Microsoft CVEs across four months. SSVC v2.0 [5] provides a stakeholder-specific decision tree. We do not re-do the cross-system disagreement comparison. We acknowledge SSVC as a non-weighted scheme outside the linear-score family we study.

**Context-feature ablations.** Sherif et al. [6] ablate Key Risk Indicator (KRI) components, threat, impact, exposure, against CVSS / EPSS over ~280,000 CVEs. Our sensitivity sweep is narrower (one public-sector-typical 31-product catalog, the EPSS v3 era, 18 monthly t0 windows, six fixed design-prior vectors); we do not learn KRI weights. We also explicitly evaluate whether within-cell seed variance dominates between-cell signal and find every axis descriptive-only under that criterion.

**Capacity-constrained prioritization.** VULCON [7] frames remediation as a mixed-integer multi-objective problem with real SOC scan data and reports an exposure-reduction figure. Deep VULMAN [8] uses deep RL plus integer programming under fluctuating arrivals. Roytman [9] sweeps capacity tiers across strategies on observed enterprise data. We do not propose a new scheduler; we use the VulnPrio study’s deterministic scheduler unchanged. Our capacity sensitivity is a confirmatory descriptive sweep, not a new algorithm.

**Foundational case-control / EPSS roots.** Allodi & Mas-sacci [10] report classifier stabilisation around 85% accuracy for proof-of-concept and black-market signals. Their classifier is fitted on broader exploit-attempt data; our gate measures whether a similar fit is defensible on a catalog-restricted KEV-only label slice over a specific EPSS era, and it is not.

**NIST LEV.** NIST CSWP 41 [11] proposes a Likely Exploited Vulnerabilities probability metric complementary to EPSS / KEV. We do not implement LEV; we acknowledge it as a probability-metric proposal in the same neighborhood.

**Field surveys and recent integrations.** Jiang et al. [12] survey 82 vulnerability-prioritization studies; VulnRG [13] ranks via system-dependency graphs; VulnScore [14] deploys a composite of human input and temporal threat intelligence; Vulnerability Management Chaining [15] reports integration efficiency. Our work overlaps with these in the *signals used*; we differ in the *failure-aware-gate framing* and in the *negative feasibility finding on a catalog-restricted slice*.

We do not claim a “first” in any of these regions. We do claim that the specific pairing of (multi-t0 distinct-positive-CVE gate) + (catalog-restricted public-feed slice) + (reproducible execution trail) is, to the best of a pre-registered literature search, not currently published as one bundle.

#### IV. PROBLEM STATEMENT

Three pre-registered research questions structure this study:

- **Q1 (Class A, calibration feasibility).** Under public-feed labels on a

31-product catalog over the EPSS v3 era, is per-feature weight calibration statistically defensible? Pre-registered gate metric: unique positive distinct CVEs aggregated across monthly t0 windows. Gate threshold:  $\geq 50$  for GO, 20-49 for CONDITIONAL,  $< 20$  for PIVOT.

- **Q2 (Class C, sensitivity).** With weights held as fixed design priors,

do the operational EHD outcomes vary across capacity ratios, blackout policies, and feature ablations? Pre-registered primary metric: paired-seed  $\Delta$ EHD with BCa CIs; a descriptive-language guardrail applies throughout.

- **Q3 (Classes E and F, audit).** Does the runtime preserve scheduler

feasibility, content-addressed audit, and the VulnPrio study’s freeze invariant on every batch? Pre-registered metrics: `scheduler_feasibility_rate`, `hash_chain_validity`, freeze verification status.

Ranking-quality metrics (precision/recall/nDCG at K) and KEV-deadline-breach metrics are diagnostic-only due to label sparsity; they appear in appendix tables but never as headline claims.

#### V. FAILURE-AWARE CALIBRATION GATE

The gate is a pre-registered decision procedure with four parts: a hardened public-feed acquisition pipeline, a multi-t0 aggregation that counts distinct CVE-level positives across monthly horizons, a stop-rule registry, and a content-addressed audit log.

**Acquisition.** The acquisition path fetches NVD disclosures in  $\leq 120$ -day chunks (the API’s per-window cap), caches each chunk for resume, paces requests, and reports HTTP-429 partial states honestly. The unauthenticated path is rate-limited; an API key is required to fetch multi-year windows. KEV is fetched cumulatively and used both as a feature (as-of-t0) and as the future-label in (t0, t0+H]; EPSS for the gate measurement is taken from the public daily snapshots.

**Multi-t0 aggregation.** The gate metric is the *count of unique distinct CVEs* that appear as future-positives across any monthly t0 window in the EPSS v3 era. A CVE positive in two windows counts once. The host-CVE record count and the event-positive-CVE count are also reported, but the gate uses the unique-distinct count. The host-CVE record count is not the calibration unit; the calibration unit is the CVE.

**Stop-rule registry.** The pre-registered stop-rule registry encodes a calibration-infeasibility threshold (fires when unique positives  $< 20$ ), a per-window label sparsity check, and four inference modifiers: a degenerate-comparison auto-drop rule, an oracle-inference disable rule, a descriptive-language guardrail (applied when a Holm rejection falls inside the meaningful-effect threshold), and a ban on significance language for diagnostic-only metrics.

**Audit log.** Every execution batch is wrapped in a freeze invariant: a pre-flight integrity check, a post-run repeat, manifest SHA identity verification, and assertions that no Paper-1 paths were modified. Every per-seed metric row carries a `freeze_witness_id` that ties it to the verified freeze state.

## VI. STUDY DESIGN AND PRE-REGISTRATION

The study was pre-registered before any execution. Six fixed design-prior weight vectors were locked at pre-registration:

- `w_uniform` (1/7 each),
- `w_paper1_placeholder` (= the VulnPrio study's `w_hand`),
- `w_epss_dominant` ( $E = 0.50$ ),
- `w_cvss_dominant` ( $S = 0.50$ ),
- `w_kev_dominant` ( $K = 0.50$ ),
- `w_context_dominant` ( $C = 0.30, X = 0.25$ ).

Each vector is a *design prior with a citation chain for the direction*, not a literature numeric estimate; reweighting after results is forbidden by pre-registration. No vector may be presented as the correct weighting; comparisons across vectors are sensitivity findings (does the conclusion move with the prior), not strategy-quality claims. The pre-registered factorial is 48 runnable cells  $\times$  30 seeds = 1,440 seed-runs across four primary batches (primary, capacity, blackout, ablation). A pilot run preceded the primary launch; the pilot-gate decision was `PROCEED_TO_PRIMARY_NO_FALLBACK`.

## VII. PUBLIC-FEED DATA AND SPARSE-LABEL FEASIBILITY

This section reports the measured gate outcome.

The full-window keyed acquisition fetched **110,224 NVD records** over 2021-09-01..2025-02-01, in 11 chunks of  $\leq 120$  days each, paced at 0.6s. Eighteen monthly t0s in the EPSS v3 era were evaluated. KEV future labels were computed in  $(t_0, t_0 + 30]$ . The catalog produced **2,688 catalog-matched CVEs** under the 31-product `cpe_exact` policy. EPSS daily snapshots covered 17 of 18 t0s at  $\geq 99.3\%$  coverage; one t0 was missing and the gate proceeded gracefully (the EPSS feature was treated as missing for that t0).

The headline value is **7 unique positive distinct CVEs**. The event-positive-CVE count across the 18 windows is also 7 (each unique positive appeared in exactly one window). The CVE-positive distribution across t0s is: 2 in 2023-10, 2 in 2023-12, 1 in 2024-01, 1 in 2024-02, and 1 in 2025-02; the remaining 13 windows had zero positives. The pre-registered PIVOT threshold is  $< 20$  unique positives; the GO threshold is  $\geq 50$ .

The calibration-infeasibility threshold triggered: the unique-positive count is below 20, and the per-window positive-count-below-3 share exceeds 75% of windows. Calibration was not attempted; learned weights were not produced and are not used anywhere in this work. Ranking-quality metrics (precision / recall / nDCG at  $K$ ) and the KEV-deadline-breach metric are therefore reported as diagnostic-only sentinels and do not enter any headline finding.

We emphasise this is a measurement on one slice. Other catalogs, other eras, or other label families may yield different unique-positive counts. We make no general claim about when calibration is or is not feasible. We make a specific claim about *this catalog  $\times$  this era  $\times$  this label*.

## VIII. FIXED-PRIOR SENSITIVITY DESIGN

Because calibration was not attempted, the second part of the work is a pre-registered sensitivity sweep with weights held

as fixed design priors. The factorial comprises 48 runnable cells across four batches:

- **Primary table (12 cells)**: 6 baseline strategies (random, `cvss_only`, `epss_only`, `kev_first`, `cvss_x_epss`, `cvss_plus_epss_plus_kev`) and 6 fixed-prior cells (one per pre-registered weight vector), all at central capacity 0.01, primary blackout, and full feature set.
- **Capacity sensitivity (15 cells)**: 5 strategies across 4 capacity levels  $\{0.005, 0.01, 0.02, 0.05\}$ ; five cells reused from primary.
- **Blackout sensitivity (9 cells)**: 3 strategies across 4 blackout policies  $\{\text{none, light, primary, strict}\}$ ; three cells reused from primary.
- **Feature ablation (12 cells)**: 2 weight vectors (`w_paper1_placeholder`, `w_context_dominant`)  $\times$  6 single-feature ablations; two full cells reused from primary.

Catalog expansion, fuzzy CPE matching, EPSS v4, PoC labels, and seed sweeps at  $n = 50$  and  $n = 100$  were pre-registered as deferred. Gradient-boosted and other learned comparators were pre-registered as forbidden because calibration was not attempted.

## IX. METRICS AND INFERENCE POLICY

The pre-registered primary metric is `ehd_absolute` (Exposure-Host-Day), reported as paired-seed  $\Delta\text{EHD}$  relative to `epss_only` at the central cell. Secondary metrics are `eehda_relative`, `fraction_of_oracle` (reported descriptively; oracle inference is disabled by pre-registration), `scheduler_feasibility_rate`, and `capacity_efficiency`. Precision, recall, nDCG at  $K$ , and KEV-deadline-breach rate are diagnostic-only due to label sparsity; these never enter a headline claim.

The pre-registered inference policy sets the meaningful-effect threshold at 5,000 host-days (chosen above the Paper-1 per-seed paired- $\Delta$  noise floor of 2,331-3,673 hd) and computes the MDE at  $n = 30$  paired seeds,  $\alpha = 0.05$ , power = 0.80, two-sided (MDE-d = 0.5292). Under  $\times 1.0$  to  $\times 1.5$  sparsity inflation the MDE in host-days sits in 1,234-2,916 hd, below the 5,000-hd meaningful threshold.

Five Holm correction families are pre-registered. Degenerate-difference comparisons are auto-dropped (`kev_first - epss_only` was identically zero under Paper-1 fixtures and is dropped if degeneracy is reproduced). Oracle inference is disabled. A descriptive-language guardrail applies whenever a Holm rejection falls inside  $\pm 5,000$  host-days. Significance phrasing is forbidden for diagnostic-only metrics.

## X. RESULTS

### A. Gate result

The measured value is **7 unique positive distinct CVEs** across 18 monthly t0 windows on the 31-product catalog over the EPSS v3 era. The pre-registered gate threshold is  $\geq 50$  for GO, 20-49 for CONDITIONAL, and  $< 20$  for PIVOT. The measured value falls in the PIVOT zone; the calibration-infeasibility threshold triggered. Calibration was not attempted.

TABLE I

PAIRED-SEED  $\Delta$ EHD RELATIVE TO EPSS\_ONLY (30 SEEDS; BCa 95% CONFIDENCE INTERVAL). NEGATIVE VALUES DENOTE FEWER HOST-DAYS OF EXPOSURE. THE FOUR BASELINE STRATEGIES FALL WITHIN THE NOISE FLOOR (DESCRIPTIVE NULL); THE FIXED-PRIOR WEIGHT VECTORS SHOW LARGER DESCRIPTIVE DIFFERENCES WHOSE INTERVALS EXCLUDE ZERO, BUT THE POST-RUN WITHIN-CELL VARIANCE CRITERION DEMOTES EVERY AXIS TO DESCRIPTIVE-ONLY.

| Strategy                | Mean $\Delta$ EHD (hd) | BCa 95% CI       |
|-------------------------|------------------------|------------------|
| cvss_only               | -163                   | [-1,918, +1,329] |
| kev_first               | +140                   | [-356, +839]     |
| cvss_x_epss             | +374                   | [-384, +1,145]   |
| cvss_plus_epss_plus_kev | +103                   | [-224, +431]     |
| w_epss_dominant         | $-2.21 \times 10^6$    | excludes zero    |
| w_cvss_dominant         | $-8.82 \times 10^6$    | excludes zero    |
| w_context_dominant      | $-1.61 \times 10^7$    | excludes zero    |

### B. Primary execution integrity

The primary execution comprises 4 batches, **48 cells**, **1,440 seed-runs**, and **8,640 metric rows**. Every row carries a `freeze_witness_id` equal to the Paper-1 manifest SHA-256 (750e144ba9567b5255b27ce40279643bdf7418d53b15edce5d72c515eb022833); zero rows are missing the witness ID. All four batches passed five freeze-integrity assertions: pre-flight check OK, post-run check OK, manifest SHA byte-equal, no Paper-1 paths modified, and no freeze bypass invoked. Data-integrity and freeze-violation hard halts did not trigger. No row uses a calibration or learned strategy.

### C. Operational EHD outcomes

The baseline `epss_only` central-cell mean EHD is  $\approx 3.32 \times 10^9$  host-days (30 seeds). Paired-seed  $\Delta$ EHD relative to `epss_only`, reported as descriptive observations:

Table I summarizes the paired-seed results.

The remaining fixed-prior vectors fall in the same range: `w_kev_dominant` ( $-2.54 \times 10^6$ ) tracks `w_epss_dominant`, `w_paper1_placeholder` ( $-8.74 \times 10^6$ ) tracks `w_cvss_dominant`, and `w_uniform` ( $-1.00 \times 10^7$ ) sits between `w_cvss_dominant` and `w_context_dominant`.

These are descriptive observations relative to EPSS. Although several  $\Delta$ EHD magnitudes exceed the 5,000-hd meaningful-effect threshold, the descriptive-language guardrail applies throughout: magnitudes are not interpreted as quality claims. No claim is made that any context-aware prior is meaningfully better than EPSS at this label sparsity (see post-run variance analysis below). Paired BCa CIs are the primary inferential quantity.

### D. Weight-family sensitivity

Fifteen pairwise comparisons across the six fixed-prior vectors are recorded. Differences in mean EHD across vectors are observed but are not interpreted as a quality ordering; the vectors are design priors, not evidence-based estimates.

### E. Capacity sensitivity

$\Delta$ EHD across consecutive capacity steps {0.005 $\rightarrow$ 0.01, 0.01 $\rightarrow$ 0.02, 0.02 $\rightarrow$ 0.05} is reported for five strategy/vector arms. Records are populated with paired BCa CIs under the descriptive guardrail.

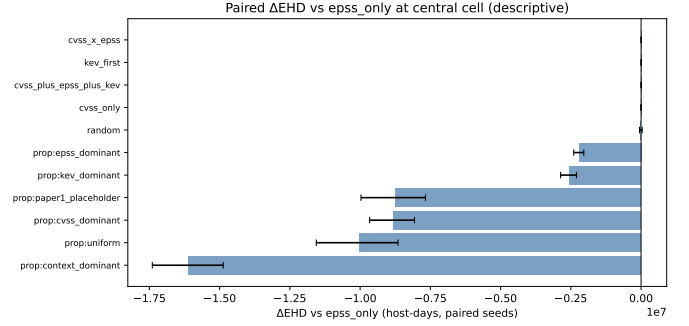


Fig. 1. Paired-seed  $\Delta$ EHD relative to `epss_only` per strategy (mean  $\pm$  BCa 95% CI, 30 seeds). All baseline strategies (`cvss_only`, `kev_first`, `cvss_x_epss`, `cvss_plus_epss_plus_kev`) fall within the noise floor. Fixed-prior context-aware priors show larger descriptive differences but remain in the descriptive-only zone per the post-run variance criterion.

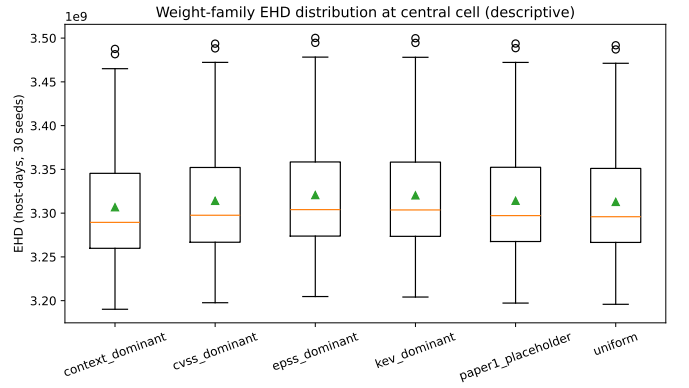


Fig. 2. Weight-family sensitivity:  $\Delta$ EHD across six fixed design-prior vectors relative to `epss_only` (mean  $\pm$  BCa 95% CI, 30 seeds). Vector differences are descriptive observations; the post-run variance criterion demotes all axes to descriptive-only.

### F. Blackout sensitivity

Blackout transitions {none  $\rightarrow$  light  $\rightarrow$  primary  $\rightarrow$  strict} are evaluated for three strategies. No cell with zero scheduler feasibility occurred; the pre-registered floor of 0.95 was not approached.

### G. Feature-ablation sensitivity

Twelve paired ablation-vs-full comparisons (two fixed-prior vectors  $\times$  six feature ablations) are reported. Where the ablation-effect sign flips between vectors, both signs are recorded; no single vector is preferred.

### H. Scheduler feasibility and audit integrity

`scheduler_feasibility_rate` = 1.0 on every primary cell. All four batches passed freeze-integrity verification; the Paper-1 freeze manifest SHA-256 was byte-equal before and after every batch.

### I. Post-run variance analysis

Three post-run checks were recorded.

- **Sensitivity measurability.** Across all four axes (capacity, weight family, feature ablation, blackout), the absolute

median paired  $\Delta$ EHD is well above the 1,000-hd null-axis threshold. Sensitivity is measurable at the cell-mean level.

- **Catalog perturbation.** One-product catalog perturbations were not executed at scale; this check is recorded as skipped and listed as a limitation.
- **Within-cell variance criterion.** The criterion fires on every primary robustness axis. The per-cell coefficient of variation across seeds ( $CV_{within} \approx 0.024$ ) exceeds the across-cells coefficient ( $CV_{across}$ , which ranges from  $\approx 0.0016$  on the weight-family axis to  $\approx 0.021$  on the capacity axis) on every axis. Each axis is therefore demoted to descriptive-only: although cell-mean differences are large, per-cell seed noise is comparable to the between-cells signal at the 30-seed budget. No sensitivity claim survives this criterion; all results above are descriptive.

## XI. DISCUSSION

Sparse public-feed labels are a methodological constraint, not a flaw in any particular model. The gate methodology is intended to surface that constraint before per-feature calibration is attempted, rather than discover it after weights have been fitted and presented. Treating the host-CVE record total as if it were the calibration unit is a misleading habit: the calibration unit is the CVE, and a few thousand records that share a handful of CVE-level labels do not provide more calibration information than the CVE count alone.

The sensitivity sweeps add reproducibility evidence and a set of axis-level descriptive observations: at the cell-mean level the priors do separate from each other, but at the seed level the per-cell variance is the same order of magnitude as the between-cells variance, the within-cell variance criterion fires on every axis. This is a useful signal in itself: it cautions against treating seed-aggregated mean EHD differences as decision evidence at this seed budget. A higher seed budget (deferred  $n = 50$  and  $n = 100$  runs) would allow this criterion to be re-evaluated.

The work says nothing about EPSS in general; the released v3-era EPSS is used as one feature among several, without retraining or critique. The work says nothing about whether KEV is an adequate ground-truth label in general; it is a sparse signal on the catalog  $\times$  era examined. The work says nothing about CVSS quality. The work does not claim that context-aware priors are meaningfully better than EPSS for prioritization; descriptive observations that some priors produce lower EHD at the central cell are reported, and the sensitivity sweeps fall in the descriptive-only zone under the variance criterion.

We do not claim production-readiness. We do not claim deployment evidence. We do not claim government use. We do not claim compliance achievement.

The negative feasibility finding is useful precisely because it is honest and small. It is a data point about a specific catalog  $\times$  era  $\times$  label choice. It does not generalise without further measurement, and we do not attempt that generalisation here.

## XII. LIMITATIONS

- **Synthetic fleet.** The fleet uses the Paper-1 synthetic generator; real-host generalisation is not claimed.
- **31-product catalog.** Catalog choice is exogenous. A catalog-expansion study is required before the negative finding can be attributed to something other than catalog narrowness.
- **CPE matching.** The matching policy is `cpe_exact` at one configuration; fuzzy and manual matching were deferred.
- **KEV-only labels.** PoC and ExploitDB labels are license-gated and were not used. The negative finding reflects KEV-only label density at the specific catalog and era; richer label families may behave differently.
- **Catalog perturbation.** Catalog stability under one-product perturbations was not measured at scale; this remains an open question.
- **EPSS v3 era only.** The study is scoped to the EPSS v3 era, bounded by the model-version transition at 2025-03-17.
- **Fixed priors are design priors.** No vector is a published numeric estimate; the citation chains motivate the *direction* of each prior, not a specific magnitude.
- **No calibration comparator.** The calibration-infeasibility threshold prevents learned-weight cells; no fitted-weight comparator is included.
- **Ranking-quality and KEV-deadline metrics are diagnostic-only** due to label sparsity. They appear in appendix tables and do not enter the headline finding.
- **Within-cell variance dominance.** The post-run variance criterion fires on every sensitivity axis, demoting each to descriptive-only at the 30-seed budget; the seed budget is itself a limitation.
- **No production-readiness.** No production validation is claimed; the pipeline is not a production system.
- **No deployment or compliance claims.** No government-deployment or compliance claim is made.

## XIII. FUTURE WORK

- **Catalog expansion.** Expand the product catalog and re-run the full gate, so the negative finding can be tested against catalog width.
- **Per-t0 EPSS.** The current study used a single cached EPSS snapshot at every t0 horizon. A future run with per-t0 EPSS snapshots would allow the EPSS feature to vary by horizon.
- **Catalog perturbation.** A one-product perturbation drift evaluation would quantify catalog stability under small changes.
- **Larger seed budget.** Sweeps at  $n = 50$  and  $n = 100$  seeds would allow the within-cell variance criterion to be re-evaluated and potentially yield inferential rather than descriptive sensitivity findings.
- **Richer exploit labels.** A licensed PoC / ExploitDB label path, under an explicit license-gate environment with no redistribution, would test whether label-family choice drives the sparsity finding.

- **LEV integration.** An evaluation incorporating NIST Likely Exploited Vulnerabilities scores [11] should be conducted once LEV scores stabilise.
- **EPSS v4 era.** A second gate measurement on the EPSS v4 era, treating v3 and v4 as separate slices, would test whether the negative finding persists across the model-version boundary.

#### XIV. CONCLUSION

This paper is a negative-result methodology paper. A pre-registered feasibility gate asked whether public-feed labels are dense enough for per-feature weight calibration on a public-sector-typical 31-product catalog over the EPSS v3 era. The gate measured only 7 unique positive distinct CVEs across 18 monthly horizons and 2,688 catalog-matched CVEs, well below the pre-registered threshold of 50. Calibration was not attempted. A pre-registered sensitivity sweep with six fixed design-prior vectors across capacity, blackout, and feature-ablation axes was executed; post-run variance analysis confirmed that within-cell seed variance dominates between-cell signal on every axis, so all sensitivity results are reported descriptively. The Paper-1 frozen artefact was preserved before and after every batch; the audit trail is content-addressed end-to-end. No claim is made that any prior is meaningfully better than EPSS, and no production-readiness is claimed. The reusable contribution is the failure-aware gate methodology plus the reproducible execution trail.

#### XV. REPRODUCIBILITY AND ARTIFACT NOTES

All execution artifacts are content-addressed and available in the accompanying repository. The pre-registration document, stop-rule registry, and cell enumeration were locked before any data collection began.

**Study design artifacts:** pre-registration document, nine pre-registered fixes, minimal factorial cell enumeration (48 cells), batch plan, and stop-rule registry.

**Gate measurement:** multi-t0 feasibility probe outputs confirming 7 unique positive CVEs across 18 monthly horizons and 2,688 catalog-matched CVEs.

**Pilot artifacts:** pilot batch results, per-batch audit logs, and the pilot-gate decision record (PROCEED\_TO\_PRIMARY\_NO\_FALLBACK).

**Primary artifacts:** primary batch results across four batches (1,440 seed-runs, 48 cells, 8,640 metric rows), per-batch audit logs, and the primary-complete status record.

**Aggregation outputs:** summary tables for primary results, sensitivity sweeps (weight family, capacity, blackout, feature ablation), scheduler feasibility, and all five pre-registered inference families; figures for each axis.

The Paper-1 frozen artifact was not modified at any point during data collection or analysis; freeze integrity verification returns OK before and after every batch.

#### REFERENCES

- [1] J. Jacobs, S. Romanosky, B. Edwards, I. Adjerid, and M. Roytman, "Exploit prediction scoring system (EPSS)," *ACM Digital Threats: Research and Practice*, 2021.
- [2] J. Jacobs, S. Romanosky, O. Suciu, B. Edwards, and A. Sarabi, "Enhancing vulnerability prioritization: Data-driven exploit predictions with community-driven insights," *arXiv preprint arXiv:2302.14172*, 2023. [Online]. Available: <https://arxiv.org/abs/2302.14172>
- [3] D. Ravalico, M. Farina, M. Trevisan, and A. Bartoli, "Analysing the temporal dynamics of the exploit prediction scoring systems (EPSS)," *SSRN preprint 5147459*, 2025.
- [4] V. Koscinski, M. Nelson, A. Okutan, R. Falso, and M. Mirakhorli, "Conflicting scores, confusing signals: An empirical study of vulnerability scoring systems," *arXiv preprint arXiv:2508.13644*, August 2025. [Online]. Available: <https://arxiv.org/abs/2508.13644>
- [5] CISA and Carnegie Mellon Software Engineering Institute, "Stakeholder-specific vulnerability categorization (SSVC) v2.0," CISA / CMU SEI Guide, 2023. [Online]. Available: <https://www.cisa.gov/sites/default/files/publications/cisa-ssvc-guide%20508c.pdf>
- [6] E. Sherif, I. Yevseyeva, V. Basto-Fernandes, and A. Cook, "Bridging the gap between security metrics and key risk indicators: An empirical framework for vulnerability prioritization," *arXiv preprint arXiv:2603.12450*, March 2026. [Online]. Available: <https://arxiv.org/abs/2603.12450>
- [7] K. A. Farris, A. Shah, G. Cybenko, R. Ganesan, and S. Jajodia, "VULCON: A system for vulnerability prioritization, mitigation, and management," *ACM Transactions on Privacy and Security*, vol. 21, no. 4, pp. 1-28, 2018.
- [8] S. Hore, A. Sharma, and S. K. Sahay, "Deep VULMAN: A deep reinforcement learning-enabled cyber vulnerability management framework," *Expert Systems with Applications*, vol. 221, p. 119734, 2023, preprint at arXiv:2208.02369.
- [9] M. Roytman, "Capacity is King," Empirical Security research note, 2024, vendor research note. [Online]. Available: <https://research.empiricalsecurity.com/research/capacity-is-king>
- [10] L. Allodi and F. Massacci, "Comparing vulnerability severity and exploits using case-control studies," *ACM Transactions on Information and System Security*, vol. 17, no. 1, 2014.
- [11] P. Mell and J. Spring, "Likely exploited vulnerabilities: A proposed metric for vulnerability exploitation probability," National Institute of Standards and Technology, Tech. Rep. NIST CSWP 41, May 2025. [Online]. Available: <https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.41.pdf>
- [12] Y. Jiang, N. Oo, Q. Meng, H. W. Lim, and B. Sikdar, "A survey on vulnerability prioritization: Taxonomy, metrics, and research challenges," *arXiv preprint arXiv:2502.11070*, February 2025. [Online]. Available: <https://arxiv.org/abs/2502.11070>
- [13] -, "VulRG: Multi-level explainable vulnerability patch ranking for complex systems using graphs," *arXiv preprint arXiv:2502.11143*, February 2025. [Online]. Available: <https://arxiv.org/abs/2502.11143>
- [14] N. Alqahtani and M. Almukaynizi, "VulnScore: A deployed system for patch prioritization combining human input and temporal threat intelligence," *International Journal of Information Security*, vol. 25, no. 1, 2025.
- [15] N. Shimizu and M. Hashimoto, "Vulnerability management chaining: An integrated framework for efficient cybersecurity risk prioritization," *IEEE Access*, vol. 14, pp. 31 407-31 424, 2026. [Online]. Available: <https://arxiv.org/abs/2506.01220>